

Explain common threat vectors and attack surfaces

Message-Based Attack Vectors

Message-based vectors use communication platforms to launch cyberattacks by exploiting user trust. These attacks often involve **social engineering**, tricking users into revealing sensitive information or executing malicious actions.

1. Email-Based Attacks

- Email is widely used in enterprises, making it a major attack vector.
- **Phishing emails** disguise themselves as legitimate messages.
- They may contain:
 - Malicious links
 - Infected attachments
- **Risks:**
 - Data breaches
 - Malware installation
 - Financial fraud

Mitigation Techniques & Purpose:

- Spam filters and anti-phishing tools → block malicious emails
- Employee training → identify suspicious emails
- Multi-Factor Authentication (MFA) → protect accounts

2. SMS-Based Attacks (Smishing)

- SMS is increasingly used for communication and authentication.
- Attackers send fraudulent messages to:
 - Steal personal information
 - Trick users into clicking malicious links

Risks:

- Credential theft
- Financial loss
- Compromise of OTP-based systems

Mitigation Techniques & Purpose:

- Avoid SMS-based authentication where possible
- Use secure authentication apps
- User awareness about suspicious messages

3. Instant Messaging (IM) Attacks

- IM platforms often use encryption but are still vulnerable.

- Attacks include:
 - Malicious file sharing
 - Fake links
 - Social engineering messages

Risks:

- Malware spread
- Unauthorized access
- Data leakage

Mitigation Techniques & Purpose:

- Restrict file sharing and unknown links
- Use enterprise-secured IM platforms
- Monitor communications

Image-Based Attack Vectors

Image-based attacks use **images as carriers of hidden malicious content** such as embedded code, malware, or harmful links. These attacks often bypass traditional security systems because images appear safe and are commonly shared through email, websites, and messaging platforms.

Risks:

- Unauthorized access
- Malware or ransomware infection
- Data breaches and system compromise

Mitigation Techniques (Purpose):

- Advanced image scanning tools → detect hidden threats
- Regular software updates → fix vulnerabilities
- Sandboxing and filtering → block suspicious images
- User awareness → avoid unknown or unsafe files

File-Based Attack Vectors

File-based attacks use **malicious files (attachments, downloads, documents)** to exploit software vulnerabilities. When opened, these files execute harmful code that can compromise systems.

Risks:

- Unauthorized system access
- Data theft
- Malware or ransomware infection
- Remote control of systems

Mitigation Techniques (Purpose):

- File screening and antivirus tools → detect malicious files
- Attachment blocking → prevent risky file types
- Software updates/patching → fix vulnerabilities
- Sandboxing → safely test suspicious files

Purpose: To intercept malicious files before execution, protect systems from compromise, and ensure enterprise data security.

Voice Call Attack Vectors

Voice call attacks exploit **telephonic communication** to deceive users into revealing sensitive information. Attackers use techniques like **caller ID spoofing** and **vishing (voice phishing)** to impersonate trusted entities.

Risks:

- Disclosure of confidential information
- Financial fraud
- Unauthorized system access

Mitigation Techniques (Purpose):

- User awareness and verification practices → avoid trusting unknown callers
- Caller authentication procedures → confirm identity before sharing data
- Call filtering/blocking systems → reduce fraudulent calls

Purpose: To prevent social engineering over voice channels, protect sensitive information, and reduce fraud in enterprise communication systems.

Vulnerable Software

Vulnerable software refers to applications or systems with **weaknesses (bugs, design flaws, outdated components)** that can be exploited by attackers to gain unauthorized access, steal data, or disrupt operations.

Causes:

- Coding errors
- Poor design
- Lack of updates/patches

Risks:

- Data breaches
- Malware infections
- System failure and financial loss
- Reputational damage

Vulnerability Scanning Methods

1. Client-Based Scanning (Agent-Based):

- Requires installation of an agent on each system
 - Continuously monitors and reports vulnerabilities to a central server
- Advantage: More detailed and real-time detection

2. Agentless Scanning:

- No installation required; scans systems remotely
 - Common tools include **Nmap** and **Wireshark**
- Advantage: Easy deployment and quick scanning

Mitigation Techniques (Purpose)

- Regular patching and updates → fix known vulnerabilities
- Secure coding practices → reduce software flaws
- Vulnerability scanning → identify and assess risks
- Patch management → ensure timely fixes

Purpose: To identify, manage, and eliminate software weaknesses, ensuring system security and reducing the risk of cyberattacks.

Unsupported Systems and Applications

Unsupported systems and applications are **outdated or legacy software** that no longer receive security updates or patches from vendors. These systems are highly vulnerable to cyberattacks.

Risks:

- Exploitation of known vulnerabilities
- Unauthorized access to systems
- Data breaches and data exfiltration
- Ransomware and large-scale attacks

Mitigation Techniques (Purpose)

- Upgrade or replace outdated systems → eliminate known weaknesses
- Apply available patches and security fixes → reduce exposure
- Network segmentation → isolate vulnerable systems
- Use security controls (firewalls, monitoring) → limit attack impact

Purpose: To minimize risks from unpatched software, protect sensitive data, and maintain a secure

Unsecure Networks

Unsecure networks are networks that lack **proper security controls**, allowing unauthorized users to access and exploit data. These include **wireless, wired, and Bluetooth networks**, each with specific vulnerabilities.

Types & Risks

1. Wireless Networks:

- Open networks without encryption transmit data in plain text
- Risk of eavesdropping and data theft (passwords, financial data)

2. Wired Networks:

- Physical access to ports can allow unauthorized entry
- Leads to data breaches and malware attacks

3. Bluetooth Networks:

- Easy pairing can allow unauthorized device connections
- Risk of data compromise and device infiltration

Mitigation Techniques (Purpose)

- **Encryption (WPA2/WPA3, secure protocols)** → protect data in transit
- **Access controls (MAC filtering, port security)** → restrict unauthorized users
- **Disable SSID broadcast & unused ports** → reduce visibility and entry points
- **Enable Bluetooth only when needed** → limit exposure time
- **Regular updates and security patches** → fix vulnerabilities

Purpose: To prevent unauthorized access, protect data transmission, and ensure secure communication across all network types in an enterprise environment.

Open Service Ports

Open service ports are network entry points that allow communication between systems and services. If left unsecured or unnecessary, they become **easy access points for attackers**.

Risks:

- Unauthorized system access
- Exploitation of services running on open ports
- Execution of malicious code
- Increased attack surface through port scanning

Mitigation Techniques (Purpose)

- Close unnecessary ports → reduce entry points for attackers
- Regular port scanning → identify exposed services
- Firewalls and access control rules → restrict traffic to trusted sources

- Service hardening → secure required ports and services

Purpose: To minimize exposure to cyber threats by reducing unnecessary network access points and preventing unauthorized system intrusion.

Default Credentials

Default credentials are **pre-set usernames and passwords** provided by manufacturers to simplify initial setup of systems, devices, or applications. If not changed, they become a major security risk.

Risks:

- Easy unauthorized access using known default logins
- Compromise of systems and applications
- Data theft or system takeover
- Credentials widely available online increase attack success

Mitigation Techniques (Purpose)

- Change default usernames and passwords immediately → prevent easy access
- Enforce strong password policies → increase credential strength
- Multi-factor authentication (MFA) → add extra security layer
- Regular security audits → detect weak or unchanged credentials

Supply Chain

A supply chain refers to the process of **producing and delivering goods or services**, involving suppliers, manufacturers, vendors, distributors, and retailers. In cybersecurity, it represents a major risk area because attackers can exploit weaker third-party connections to access larger enterprise systems.

Key Components & Risks

1. Managed Service Providers (MSPs):

- Third-party IT service providers managing company systems
- Risk: A single breach can affect multiple client organizations

Mitigation: Security audits, strict access control, regular patching

Purpose: Prevent cascading attacks across multiple clients

2. Vendors:

- External organizations sharing data or services
- Risk: Weak vendor security can expose enterprise systems

Mitigation: Vendor risk assessments, security agreements, continuous monitoring

Purpose: Ensure secure handling of shared data and services

3. Suppliers:

- Providers of goods, components, or services in the production chain
- Risk: Weak security at supplier level can become an entry point for attackers

Mitigation: Due diligence, security compliance checks, contractual security requirements

Purpose: Prevent attackers from entering through weak supply chain links

Overall Supply Chain Risks

- Third-party compromise leading to enterprise breach
- Data leakage through external partners
- Weak security at supplier/vendor level exploited by attackers

Overall Purpose of Mitigation

- Secure all external dependencies
- Prevent indirect attacks through third parties
- Maintain trust and integrity across the entire supply chain